

FreightFlow ERP - Backend Development Rulebook v1

1. Technology Stack

Backend:

- Node.js
- Express.js
- PostgreSQL

ORM:

- Sequelize

Authentication:

- JWT
- Access Token
- Refresh Token

Validation:

- Joi

Logging:

- Winston

Database IDs:

- UUID

File Storage:

- uploads/ (Phase 1)
- AWS S3 (Future)

2. Folder Structure

src/

config/

database/

- connection.js

middlewares/

- auth.middleware.js
- permission.middleware.js
- error.middleware.js
- audit.middleware.js

utils/

- logger.js
- response.js
- jwt.js
- bcrypt.js

modules/

auth/

- auth.routes.js
- auth.controller.js
- auth.service.js
- auth.validation.js

users/

- users.routes.js
- users.controller.js
- users.service.js
- users.validation.js

roles/ permissions/

jobs/ customers/ quotations/ documents/ billing/ notifications/

uploads/

logs/

app.js

server.js

3. Environment Variables

.env

PORT=

DB_HOST= DB_PORT= DB_NAME= DB_USER= DB_PASSWORD=

JWT_ACCESS_SECRET= JWT_REFRESH_SECRET=

ACCESS_TOKEN_EXPIRY=15m REFRESH_TOKEN_EXPIRY=7d

UPLOAD_PATH=

4. Universal API Response Structure

Success

```
{ status: true, code: "LOGIN_SUCCESS", message: "User authenticated successfully", messageToShow: "Login successful", data: {} }
```

Error

```
{ status: false, code: "INVALID_CREDENTIALS", message: "Password mismatch", messageToShow: "Invalid email or password", data: null }
```

Rules:

status

- For frontend checking

code

- For frontend business logic

message

- For developers

messageToShow

- Directly show to user

data

- Response payload
-

5. Database Standards

Every table must contain:

id UUID PRIMARY KEY

created_at updated_at

created_by updated_by

deleted_at deleted_by

is_deleted BOOLEAN

6. Authentication Module

Login Only

Input:

email password

Flow:

Request ↓ Joi Validation ↓ Find User ↓ Verify Password ↓ Generate Access Token ↓ Generate Refresh Token ↓ Store Refresh Token ↓ Create Login Audit Log ↓ Return Response

7. Password Security

Never store passwords directly.

Use bcrypt.

Registration:

Password ↓ Hash + Salt ↓ Store Hash

Login:

Password ↓ bcrypt.compare() ↓ Match

bcrypt rounds:

10

8. Access Token

Purpose:

Authorize APIs

Expiry:

15 minutes

Stored:

Frontend Memory

Contains:

user_id email

9. Refresh Token

Purpose:

Generate New Access Token

Expiry:

7 days

Stored:

HTTP Only Cookie

Database Table:

refresh_tokens

Fields:

id user_id token expires_at

10. Logout Flow

Request

Logout ↓ Delete Refresh Token ↓ Create Audit Log ↓ Success Response

11. Roles & Permissions

Tables

roles

permissions

user_roles

role_permissions

Structure

User ↓ Multiple Roles ↓ Multiple Permissions

Examples

invoice.create

invoice.update

invoice.delete

job.create

job.update

12. Permission Middleware

Every Route Must Be Protected

Example

POST /invoice

Required Permission

invoice.create

Flow

JWT Verify ↓ Get User Permissions ↓ Check Permission ↓ Allow / Deny

13. Validation Rules

Every Request Must Pass Joi

Never Trust Frontend

Validate:

email

mobile

gst

password

uuid

pagination

dates

amounts

14. Controller Rules

Controller Responsibilities:

Receive Request

Validate Input

Call Service

Return Response

Nothing Else

No Business Logic

15. Service Rules

All Business Logic Goes Here

Example

Create Invoice

Calculate Tax

Generate Number

Audit Log

Notification

Database Operations

16. Logging Standards

Use Winston

Log Levels

INFO

WARN

ERROR

DEBUG

Log:

Login

Logout

Invoice Created

Payment Received

API Failures

Database Failures

External API Failures

17. Audit Trail Standards

Track:

CREATE

UPDATE

DELETE

LOGIN

LOGOUT

Table:

audit_logs

Fields:

id

table_name

record_id

action

old_value

new_value

changed_by

changed_at

18. Error Handling

Single Global Error Middleware

Never:

try-catch in every controller

Use:

next(error)

Error Middleware Handles Everything

19. Security Checklist

Helmet

CORS

Rate Limiter

Password Hashing

JWT

Refresh Token Rotation

HTTP Only Cookies

Parameterized Queries

Joi Validation

20. File Upload Standards

uploads/

customers/

jobs/

invoices/

documents/

boe/

shipping-bills/

profile/

Database Stores

file_name

file_path

mime_type

size

21. Soft Delete Rules

Never Delete Data

Instead

is_deleted = true

deleted_at = current_timestamp

deleted_by = user_id

22. API Versioning

All APIs

/api/v1/

Examples

/api/v1/auth/login

/api/v1/jobs

/api/v1/customers

/api/v1/invoices

23. Development Sequence

Step 1 Database Setup

Step 2 User Module

Step 3 Roles Module

Step 4 Permissions Module

Step 5 Auth Module

Step 6 Refresh Token Module

Step 7 RBAC Middleware

Step 8 Logging

Step 9 Audit Trail

Step 10 File Upload

Step 11 Customers Module

Step 12 Quotation Module

Step 13 Jobs Module

Step 14 Documents Module

Step 15 Billing Module

Step 16 Notifications Module

Step 17 Reports Module

Golden Rule

Controller = Thin

Service = Smart

Database = Source of Truth

Audit Everything

Never Trust Frontend

Never Hard Delete

Everything Versioned

Everything Logged